

PIPELINE DE SEGURANÇA · CP05

DevSecOps com evidências

Repositório de referência com Dockerfile, site estático e três barreiras bloqueantes: segredos, padrões vulneráveis e CVEs críticos.

GITLEAKS	SEMGREP	TRIVY
COMMIT SINTÉTICO bloqueado · exit 1	eval(input()) finding ERROR	IMAGEM CP05 0 CVEs reportados

Escopo e proveniência

As verificações e sabotagens foram executadas no Sandbox com Gitleaks 8.30.1, Semgrep 1.179.0 e Trivy 0.75.0. A imagem foi construída do Dockerfile do projeto via Podman, exportada como Docker archive e examinada pelo Trivy. No workflow, as Actions estão fixadas por SHA e a imagem Semgrep por digest. Os quadros visuais a seguir foram compostos a partir das **saídas textuais reais das CLIs**; não são screenshots da interface nem da aba GitHub Actions.

Limitação importante: o conector GitHub está desativado e não há repositório remoto conectado nesta execução. Portanto, o arquivo `.github/workflows/security.yml` foi criado e validado localmente, mas não foi executado na infraestrutura GitHub Actions. Uma execução remota real e seus screenshots exigem conectar e executar o workflow em um repositório autorizado.

Para bloquear merges, além do workflow, habilite proteção da branch principal e marque os três checks como obrigatórios. Se uma chave real vazar, revogue-a e rotacione-a imediatamente; remover o texto do commit não invalida a credencial.

1. Gitleaks — credencial não passa

Uma tentativa de commit com token sintético foi **rejeitada pelo hook local** antes de criar o commit. Depois, apenas na fixture descartável, o hook foi ignorado para criar um commit de teste e confirmar que o scan Gitleaks da árvore também falha com exit code 1. O valor foi redigido e o diretório temporário removido. No workflow, a action examina o histórico completo (`fetch-depth: 0`), e a branch principal entregue foi verificada sem findings.

```
EXECUÇÃO LOCAL · GITLEAKS CLI 8.30.1

$ git commit -m 'test: inject synthetic credential'
pre-commit hook: BLOQUEADO por Gitleaks; commit não criado (exit 1)
12:12AM INF scanned ~93 bytes (93 bytes) in 10.2ms
12:12AM WRN leaks found: 1
branch temporária: proof/gitleaks-secret
commit descartável para simular CI: 1790233
scan exit code: 1 (esperado: != 0)
resultado: BLOQUEADO — finding detectado; token descartável/redigido

12:12AM INF scanned ~93 bytes (93 bytes) in 10.4ms
12:12AM WRN leaks found: 1
```

Registro de saída local da CLI. O commit de sabotagem temporário não foi incorporado ao repositório entregue.

2. Semgrep — eval é um finding bloqueante

A regra local `.semgrep.yml` identifica `eval(...)` em código Python com severidade `ERROR`. O teste gravou temporariamente `eval(user_input)`, e o Semgrep reportou a regra `cp05.python.dynamic-eval` como finding bloqueante; com `--error`, o comando saiu com código 1. O scan da branch limpa retornou zero findings. A barreira reduz o risco de injeção de código e orienta substituição por parsing explícito ou operações permitidas.



```
EXECUÇÃO LOCAL · SEMGREP CLI 1.179.0

$ semgrep scan --config .semgrep.yml --error <arquivo-de-teste>
exit code: 1 (esperado: != 0)
resultado: FINDING ERROR — regra cp05.python.dynamic-eval

Findings: 1 (1 blocking)
Rule: cp05.python.dynamic-eval
Severity: ERROR / Blocking
Code: eval(user_input)
```

Registro local: um finding, regra identificada e linha vulnerável apontada.

3. Trivy — CVEs críticos na imagem

O Trivy examinou a imagem real construída do Dockerfile do CP05. A camada do sistema operacional foi identificada como Alpine 3.24.2; o relatório do scan registrou **zero vulnerabilidades conhecidas** e o gate CRITICAL terminou com exit code 0. A política do workflow usa `severity: CRITICAL` e `exit-code: 1` sem ignorar CVEs não corrigidos, portanto qualquer CVE crítico reportado bloqueia o job.

```
● ● ● EXECUÇÃO LOCAL · TRIVY 0.75.0 · IMAGEM CP05

$ trivy image --input <cp05-site.docker.tar> --severity UNKNOWN,LOW,MEDIUM,HIGH,CRITICAL --format table
Detected OS: alpine 3.24.2
Packages scanned: 70

Report Summary
/tmp/cp05-site.docker.tar | alpine | vulnerabilities: 0

Gate CRITICAL exit code: 0 (imagem limpa)
```

Scan local da imagem construída para este projeto. O resultado limpo é um retrato do banco Trivy na data/hora da execução, não uma garantia futura.

Prova de bloqueio

Como teste adicional de sabotagem, o mesmo gate examinou `alpine:3.12`, uma base fora de suporte. O Trivy encontrou **CVE-2022-37434** em zlib (CRITICAL; versão instalada 1.2.12-r0, corrigida em 1.2.12-r2) e retornou **exit code 1**. A distribuição está obsoleta e a própria ferramenta alerta que a cobertura pode ser incompleta; ela foi usada somente como fixture de teste, nunca como base do site.

```
● ● ● EXECUÇÃO LOCAL · TRIVY 0.75.0 · TESTE DE SABOTAGEM

$ trivy image --severity CRITICAL --exit-code 1 alpine:3.12
Detected OS: alpine 3.12.12 (EOL)
Total: 1 (CRITICAL: 1)
CVE-2022-37434 | zlib 1.2.12-r0 | fixed 1.2.12-r2
CWE: heap-based buffer over-read and overflow
exit code da política CRITICAL: 1 (BLOQUEADO)
```

Teste local de política com uma imagem deliberadamente vulnerável; não é a imagem do CP05.

Conclusão: as três regras foram exercitadas localmente e mostraram o comportamento esperado de pass/fail. Para converter estas provas em capturas reais do GitHub Actions, conecte o GitHub, execute o workflow no repositório de destino e substitua os registros locais pelas páginas da execução remota.